

Operating System Security

Operating System Hardening

Hardening of the OS is the act of configuring an OS securely, updating it, creating rules and policies to help govern the system in a secure manner, and removing unnecessary applications and services. This is done to minimize a computer OS's exposure to threats and to mitigate possible risk.

6 OS Hardening Tips

While different operating systems have their own intricacies, there are recommended practices that apply universally. This list is not all-inclusive and you may implement additional system hardening best practices when applicable. However, in order to minimize clients' risk of suffering a cyber attack, adhere to the following protocol:

1. Programs clean-up – Remove unnecessary programs. Every program is another potential entrance point for a hacker. Cleaning these out helps you limit the number of ways in. If the program is not something the company has vetted and "locked down," it shouldn't be allowed. Attackers look for backdoors and security holes when attempting to compromise networks. Minimize their chances of getting through.

2. Use of service packs – Keep up-to-date and install the latest versions. It's that simple. No one thing ensures protection, especially from zero-day attacks, but this is an easy rule to follow.

3. Patches and patch management – Planning, testing, implementing and auditing patch management software should be part of a regular security regimen. Make sure the OS is patched regularly, as well as the individual programs on the client's computer.

4. Group policies – Define what groups can or can't access and maintain these rules. Sometimes, it's simply user error that leads to a successful cyber attack. Establish or update user policies and ensure all users are aware and comply with these procedures. For example, everyone should be [implementing strong passwords](#), securing their credentials and changing them regularly.

5. Security templates – Groups of policies that can be loaded in one procedure; they are commonly used in corporate environments.

6. Configuration baselines – Baselining is the process of measuring changes in networking, hardware, software, etc. To create a baseline, select something to measure and measure it consistently for a period of time. Establish baselines and measure on a schedule that is acceptable to both your standard for maintaining security and meeting your clients' needs.

General Steps for securing windows operating system

Microsoft Windows is one of the most widely used Operating Systems ever. The great popularity of the feature-rich operating system has come at a price: With millions of lines of code in Windows, the Operating System has required hundreds of patches to ensure that it can be securely used on the Internet.

Unsecured computers that are directly connected to the Internet pose a threat to all users of the network. By compromising a single computer on a network, it may be possible an intruder to gain access to files, gather personal information, and disrupt the normal operations of the network. It is therefore imperative that we take precautions when connecting any computer to the campus network and Internet.

There are several steps one should take to ensure to secure a Windows computer when connecting it to the campus network:

1. Activate the Windows Firewall **before** connecting the computer to the network. Attacks can happen very quickly once a computer is connected, often within minutes or even seconds. You may not have time after plugging in the network cord to activate the firewall before your computer is compromised.
2. Apply all current patches via Windows Update. It may be necessary to reboot the computer several times during this process. You should repeat this step as needed until there are no more critical or recommended patches that need to be applied.
3. Turn on Automatic Updates so that your computer will continue to receive patches as they are released.
4. Make sure all local accounts including the built-in local administrator or owner account have strong passwords. A strong password will be 6 or more characters in length, contain both numbers and letters as well as special characters, and not be found in a dictionary. Microsoft has advice on how to create strong passwords.
5. Install and use virus protection software.
6. Install and use spyware removal software.

Keep Current!

It is important to realize that the methods used to compromise computer security are constantly changing. Minimizing your computer's risk of compromise is therefore not a one-time task. It is instead a process that must be repeated and reviewed to ensure your computer remains secure.

Keep your software current. Many vendors, Microsoft included, only make security patches available for the most current releases of software. Be sure to know your vendor's policies and plan accordingly.

Keep Clean!

Every piece of software installed on a computer adds to the risk of compromise. Some software will install unexpected extras that may include viruses, spyware, or just unseen components that may be compromised later to gain access to your system. Unneeded software will often be neglected and left without updates, eventually leading to a compromise through neglect. Therefore we encourage you to install only the applications you need and only from trusted sources. When installing new software, be sure you have a backup of your system and do not install unknown software on critical servers.

Web browsers and instant messenger clients are a common source of malware. While these products are often inextricable from a desktop system, their use on a server system should be carefully avoided. Many unpatched vulnerabilities exist for today's browsers and websites with malicious code hidden within exist just waiting to trick unsuspecting users into accessing them. When using a web browser as a user with administrator privileges be sure to only browse known websites such as www.microsoft.com.

Protect University Data!

University data, including student data, financial records, and health information require special protections and handling. Contact your Data Security Administrator for advice on safe handling of university data.

Do not install any unnecessary applications or free/share ware on any system you care about or can not easily restore from scratch.

Many modern viruses are taking advantage of all versions of instant messaging applications such as IRC, MSN, and AOL to install trojan and spyware software on systems without your knowledge. Applications of this nature have no business on a workstation housing university data. Use caution when using any application of this type and be sure to read the product documentation indicating how to secure the application on workstations determined to benefit (if any) from this type of application.

Refrain from browsing the web from a "critical" workstation. Use caution when browsing any untrusted websites.

Promote Awareness about Computer Security

Many of our incidents originate from end-user actions whether they have installed new software, answered a phishing email, or disabled antivirus software. Computer administrators cannot hope to keep computer secure unless we make computer users more aware about the importance of computer security.

Hardening steps for unix/linux based operating system

Use the following tips to harden your own Linux box.

1-Document the host information

Each time you work on a new Linux hardening job, you need to create a new document that has all the checklist items listed in this post, and you need to check off every item you applied. Furthermore, on the top of the document, you need to include the Linux host information:

- Machine name
- IP address
- Mac address
- Name of the person who is doing the hardening (most likely you)
- Date
- Asset Number (If you're working for a company, then you need to include the asset number that your company uses for tagging hosts.)

2-BIOS protection

You need to protect the BIOS of the host with a password so the end-user won't be able to change and override the security settings in the BIOS; it's important to keep this area protected from any changes. Each computer manufacturer has a different set of keys to enter the BIOS mode, then it's a matter of finding the configuration where you set the administrative password.

Next, you need to disable the booting from external media devices (USB/CD/DVD). If you omit to change this setting, anyone can use a USB stick that contains a bootable OS and can access your OS data.

The latest servers' motherboards have an internal web server where you can access them remotely. Make sure to change the default password of the admin page or disable it if it's possible.

3-Hard disk encryption (confidentiality)

Most of the Linux distributions will allow you to encrypt your disks before installation. Disk encryption is important in case of theft because the person who stole your computer won't be able to read your data if they connect the hard disk to their machine.

In the image below, choose the third option from the list: *Guided-use entire disk and set up encrypted LVM* (LVM stands for logical volume manager.)



If your Linux distribution doesn't support encryption, you can go with a software like *TrueCrypt*.



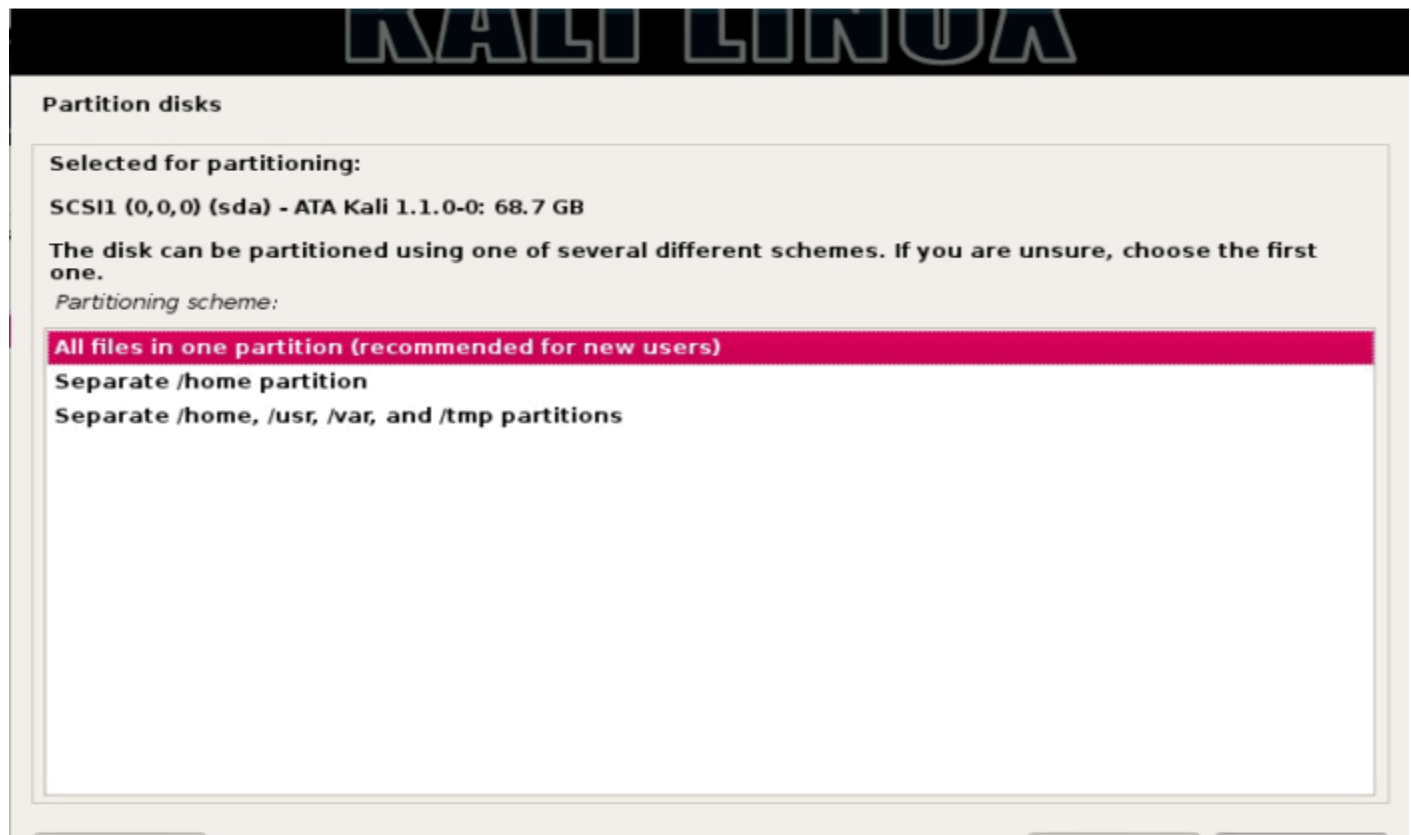
4-Disk protection (availability)

Backups have so many advantages in case of a damaged system, bugs in the OS update. For important servers, the backup needs to be transferred offsite in case of a disaster. Backup needs to be managed as well. For example, how long will you keep the old backups? When do you need to backup your system (every day, every week ...)?

Critical systems should be **separated** into different **partitions** for:

- /
- /boot
- /usr
- /home
- /tmp
- /var
- /opt

Portioning disks gives you the opportunity of performance and security in case of a system error. In the picture below, you can see the option of how to separate partitions in Kali Linux during the installation.



5-Lock the boot directory

The boot directory contains important files related to the Linux kernel, so you need to make sure that this directory is locked down to read-only permissions by following the next simple steps. First, open the “fstab” file.

```
root@kali:~# nano /etc/fstab
```

Then, add the last line highlighted at the bottom.

```
root@kali: ~
File Edit View Search Terminal Help
GNU nano 2.5.1 File: /etc/fstab Modified

# /etc/fstab: static file system information.
#
# Use 'blkid' to print the universally unique identifier for a
# device; this may be used with UUID= as a more robust way to name devices
# that works even if disks are added and removed. See fstab(5).
#
# <file system> <mount point> <type> <options> <dump> <pass>
# / was on /dev/sda1 during installation
UUID=3fdab810-22d0-4adb-890a-115c97a152a6 / ext4 errors=rem$
# swap was on /dev/sda5 during installation
UUID=8fc437fa-9f4a-49f7-8100-cb1882ff079e none swap sw $
/dev/sr0 /media/cdrom0 udf,iso9660 user,noauto 0 0
LABEL=/boot /boot ext2 defaults,ro 1 2
```

When you finish editing the file, you need to set the owner by executing the following command:

```
#chown root:root /etc/fstab
```

Next, I set few permissions for securing the boot settings:

- Set the owner and group of /etc/grub.conf to the root user:

```
#chown root:root /etc/grub.conf
```

- Set permission on the /etc/grub.conf file to read and write for root only:

```
#chmod og-rwx /etc/grub.conf
```

- Require authentication for single-user mode:

```
#sed -i "/SINGLE/s/sushell/sulogin/" /etc/sysconfig/init
```

```
#sed -i "/PROMPT/s/yes/no/" /etc/sysconfig/init
```

6-Disable USB usage

Depending on how critical your system is, sometimes it's necessary to disable the USB sticks usage on the Linux host. There are multiple ways to deny the usage of USB storage; here's a popular one:

Open the "blacklist.conf" file using your favorite text editor:

```
#nano /etc/modprobe.d/blacklist.conf
```

When the file opens, then add the following line at the end of the file (save and close):

```
blacklist usb_storage
```

After this, open the rc.local file:

```
#nano /etc/rc.local
```

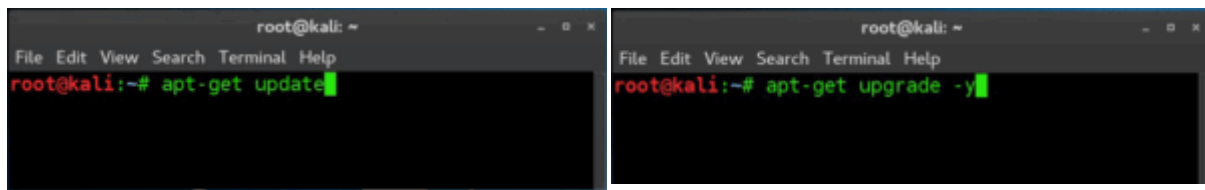
Finally, add the following two lines:

```
modprobe -r usb_storage
```

```
exit 0
```

7-System update

The first thing to do after the first boot is to update the system; this should be an easy step. Generally, you open your terminal window and execute the appropriate commands. In Kali Linux, you achieve this by executing the commands in the picture below:



8-Check the installed packages

List all packages installed on your Linux OS and remove the unnecessary ones. You need to be very strict if the host you're trying to harden is a server because servers need the least number of

applications and services installed on them. Here's an example of how to list the packages installed on Kali Linux:

```
root@kali:~# apt-cache pkgnames
libdatrie-doc
libfstrcmp0-dbg
librime-data-sampheng
python-pyao-dbg
task-estonian
fonts-georgewilliams
```

Remember that disabling unnecessary services will reduce the attack surface, so it is important to remove the following legacy services if you found them installed on the Linux server:

- Telnet server
- RSH server
- NIS server
- TFTP server
- TALK server

9-Check for open ports

Identifying open connections to the internet is a critical mission. In Kali Linux, I use the following command to spot any hidden open ports:

```
root@kali:~# netstat -antp
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
PID/Program name
tcp        0      0 0.0.0.0:22              0.0.0.0:*              LISTEN
1947/sshd
tcp6       0      0 :::22                  :::*                    LISTEN
1947/sshd
root@kali:~#
```

10-Secure SSH

Yes, indeed SSH is secure, but you need to harden this service as well. First of all, if you can disable SSH, that's a problem solved. However, if you want to use it, then you have to change the default configuration of SSH. To do it, browse to /etc/ssh and open the "sshd_config" file using your favorite text editor.

```
root@kali:~# nano /etc/ssh/sshd_config
```

- Change the default port number 22 to something else e.g. 99.
- Make sure that root cannot login remotely through SSH:

```
PermitRootLogin no
```

- Allow some specific users:

```
AllowUsers [username]
```

The list can go on and on, but these should be enough to start with. For example, some companies add banners to deter attackers and discourage them from continuing further. I encourage you to check the manual of the SSH to understand all the configurations in this file. Here are some additional options that you need to make sure exist in the “sshd_config” file:

- Protocol2
- IgnoreRhosts to yes
- HostbasedAuthentication no
- PermitEmptyPasswords no
- X11Forwarding no
- MaxAuthTries 5
- Ciphers aes128-ctr,aes192-ctr,aes256-ctr
- ClientAliveInterval 900
- ClientAliveCountMax 0
- UsePAM yes

Finally, set the permissions on the sshd_config file so that only root users can change its contents:

```
#chown root:root /etc/ssh/sshd_config
```

```
#chmod 600 /etc/ssh/sshd_config
```

11- Enable SELinux

Security Enhanced Linux is a Kernel security mechanism for supporting access control security policy. The SELinux has three configuration modes:

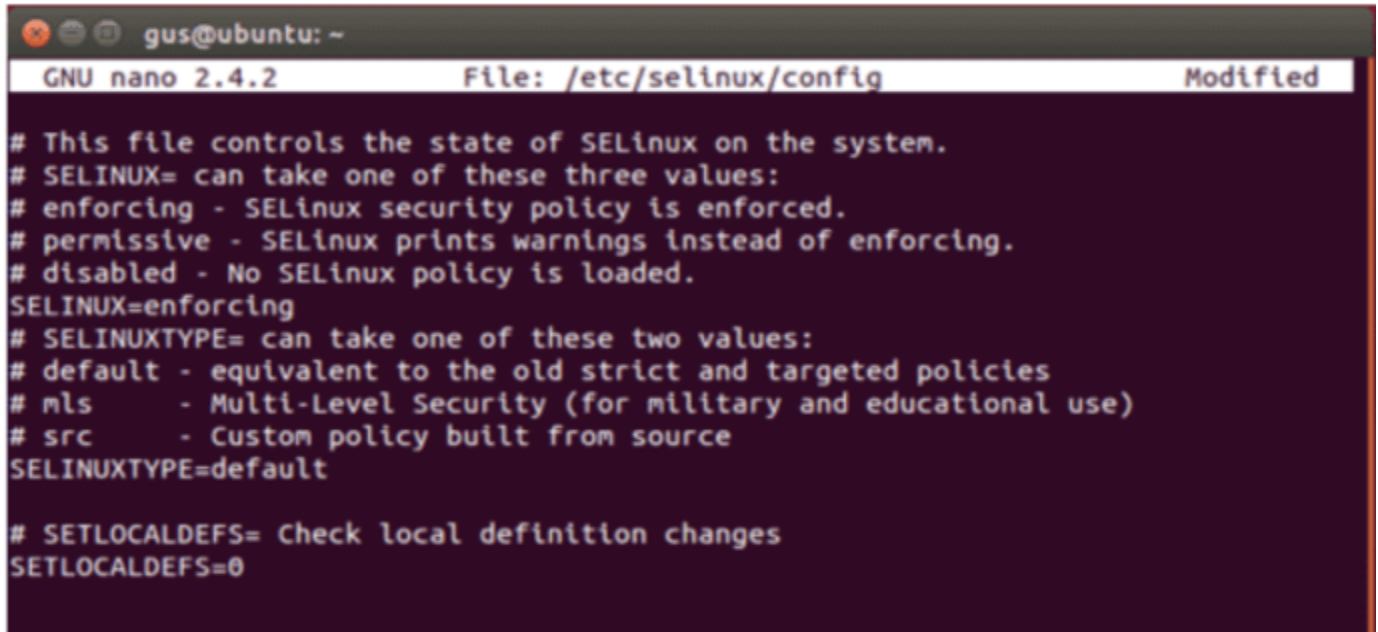
- Disabled: Turned-off
- Permissive: Prints warnings
- Enforcing: Policy is enforced

Using a text editor, open the config file:

```
#nano /etc/selinux/config
```

And make sure that the policy is enforced:

SELINUX=enforcing

A screenshot of a terminal window on an Ubuntu system. The window title is 'gus@ubuntu: ~'. The terminal shows the GNU nano 2.4.2 editor editing the file /etc/selinux/config. The file content is as follows:

```
# This file controls the state of SELinux on the system.
# SELINUX= can take one of these three values:
# enforcing - SELinux security policy is enforced.
# permissive - SELinux prints warnings instead of enforcing.
# disabled - No SELinux policy is loaded.
SELINUX=enforcing
# SELINUXTYPE= can take one of these two values:
# default - equivalent to the old strict and targeted policies
# mls      - Multi-Level Security (for military and educational use)
# src      - Custom policy built from source
SELINUXTYPE=default

# SETLOCALDEFS= Check local definition changes
SETLOCALDEFS=0
```

12- Network parameters

Securing your Linux host network activities is an essential task. Don't always assume that your firewall will take care of everything. Here are some important features to consider for securing your host network:

- **Disable the IP Forwarding** by setting the `net.ipv4.ip_forward` parameter to 0 in `"/etc/sysctl.conf"`
- **Disable the Send Packet Redirects** by setting the `net.ipv4.conf.all.send_redirects` and `net.ipv4.conf.default.send_redirects` parameters to 0 in `"/etc/sysctl.conf"`
- **Disable ICMP Redirect Acceptance** by setting the `net.ipv4.conf.all.accept_redirects` and `net.ipv4.conf.default.accept_redirects` parameters to 0 in `"/etc/sysctl.conf"`
- **Enable Bad Error Message Protection** by setting the `net.ipv4.icmp_ignore_bogus_error_responses` parameter to 1 in `"/etc/sysctl.conf"`

I strongly recommend using the **Linux Firewall** by applying the iptable rules and filtering all the incoming, outgoing and forwarded packets. Configuring your iptables rules will take some time, but it's worth the pain.

13- Password policies

People often [reuse their passwords](#), which is a bad security practice. The old passwords are stored in the file “/etc/security/opasswd”. We are going to use the PAM module to manage the security policies of the Linux host. Under a debian distro, open the file “/etc/pam.d/common-password” using a text editor and add the following two lines:

```
auth    sufficient pam_unix.so likeauth nullok
```

```
password    sufficient pam_unix.so remember=4 (Will not allow users to reuse the last four passwords.)
```

Another password policy that should be forced is **strong passwords**. The PAM module offers a pam_cracklib that protects your server from dictionary and brute-force attacks. To accomplish this task, open the file /etc/pam.d/system-auth using any text editor and add the following line:

```
/lib/security/$ISA/pam_cracklib.so retry=3 minlen=8 lcredit=-1 ucredit=-2 dcredit=-2 ocredit=-1
```

Linux will hash the password to avoid saving it in cleartext so, you need to make sure to define a secure password **hashing algorithm** SHA512.

Another interesting functionality is to **lock the account after five failed attempts**. To make this happen, you need to open the file “/etc/pam.d/password-auth” and add the following lines:

```
auth required pam_env.so
```

```
auth required pam_faillock.so preauth audit silent deny=5 unlock_time=604800
```

```
auth [success=1 default=bad] pam_unix.so
```

```
auth [default=die] pam_faillock.so authfail audit deny=5 unlock_time=604800
```

```
auth sufficient pam_faillock.so authsucc audit deny=5 unlock_time=604800
```

```
auth required pam_deny.so
```

We're not done yet; one additional step is needed. Open the file “/etc/pam.d/system-auth” and make sure you have the following lines added:

```
auth required pam_env.so
```

```
auth required pam_faillock.so preauth audit silent deny=5 unlock_time=604800
```

```
auth [success=1 default=bad] pam_unix.so

auth [default=die] pam_faillock.so authfail audit deny=5 unlock_time=604800

auth sufficient pam_faillock.so authsucc audit deny=5 unlock_time=604800

auth required pam_deny.so
```

After five failed attempts, only an administrator can unlock the account by using the following command:

```
# /usr/sbin/faillock --user <userlocked> --reset
```

Also, another good practice is to set the **password to expire after 90 days**, to accomplish this task you need to:

- Set the PASS_MAX_DAYS parameter to 90 in “/etc/login.defs”
- Change the active user by executing the following command :

```
#chage --maxdays 90 <user>
```

The next tip for enhancing the passwords policies is to **restrict access to the su command** by setting the pam_wheel.so parameters in “/etc/pam.d/su”:

```
auth required pam_wheel.so use_uid
```

The final tip for passwords policy is to **disable the system accounts** for non-root users by using the following bash script:

```
#!/bin/bash

for user in `awk -F: '($3 < 500) {print $1 }' /etc/passwd`; do

if [ $user != "root" ]

then

/usr/sbin/usermod -L $user

if [ $user != "sync" ] && [ $user != "shutdown" ] && [ $user != "halt" ]

then /usr/sbin/usermod -s /sbin/nologin $user

fi

fi

done
```

14-Permissions and verifications

Prepare yourself mentally because this is going to be a long list. But, permissions is one of the most important and critical tasks to achieve the security goal on a Linux host.

Set User/Group Owner and Permission on “/etc/anacrontab”, “/etc/crontab” and “/etc/cron.*” by executing the following commands:

```
#chown root:root /etc/anacrontab
```

```
#chmod og-rwx /etc/anacrontab
```

```
#chown root:root /etc/crontab
```

```
#chmod og-rwx /etc/crontab
```

```
#chown root:root /etc/cron.hourly
```

```
#chmod og-rwx /etc/cron.hourly
```

```
#chown root:root /etc/cron.daily
```

```
#chmod og-rwx /etc/cron.daily
```

```
#chown root:root /etc/cron.weekly
```

```
#chmod og-rwx /etc/cron.weekly
```

```
#chown root:root /etc/cron.monthly
```

```
#chmod og-rwx /etc/cron.monthly
```

```
#chown root:root /etc/cron.d
```

```
#chmod og-rwx /etc/cron.d
```

Set the right and permissions on “/var/spool/cron” for “root crontab”

```
#chown root:root <crontabfile>
```

```
#chmod og-rwx <crontabfile>
```

Set User/Group Owner and Permission on “passwd” file

```
#chmod 644 /etc/passwd
```

#chown root:root /etc/passwd

Set User/Group Owner and Permission on the “group” file

#chmod 644 /etc/group

#chown root:root /etc/group

Set User/Group Owner and Permission on the “shadow” file

#chmod 600 /etc/shadow

#chown root:root /etc/shadow

Set User/Group Owner and Permission on the “gshadow” file

#chmod 600 /etc/gshadow

#chown root:root /etc/gshadow

15- Additional process hardening

For this last item in the list, I’m including some additional tips that should be considered when hardening a Linux host.

First, restrict core dumps by:

- Adding hard core 0 to the “/etc/security/limits.conf” file
- Adding fs.suid_dumpable = 0 to the “/etc/sysctl.conf” file

Second, configure Exec Shield by:

- Adding kernel.exec-shield = 1 to the “/etc/sysctl.conf” file

Third, enable randomized Virtual Memory Region Placement by:

- Adding kernel.randomize_va_space = 2 to the “/etc/sysctl.conf” file